



POST-EXPLOITATION & EXFILTRATION LAB

Technical Report & Documentation

Intern Name: Arsalan Rasool Rather

Organization: CyArt

Program: Red Teaming Internship

Week: Week 3

Tools Used:- Mimikatz, Exfiltool, dnscat2

⚠ ETHICAL NOTICE: All post-exploitation and exfiltration activities in this lab were performed exclusively within an isolated Windows VM environment. No real credentials, personal data, or live network traffic were involved. All hash values and data shown are simulated test values. This exercise is conducted under the Cyart Internship Program for educational and defensive awareness purposes only.



1. Objective

The objective of this lab is to simulate post-exploitation techniques on a compromised Windows VM, specifically credential harvesting using Mimikatz and mock data exfiltration using DNS tunneling. The exercise demonstrates how attackers maintain value from a compromised host by extracting credentials and covertly moving data out of a network — and how defenders can detect and prevent these actions.

2. Tools & Environment

2.1 Tools Used

- Mimikatz — Open-source Windows credential extraction tool developed by Benjamin Delpy. It reads authentication credentials (NTLM hashes, Kerberos tickets, plaintext passwords) from Windows memory (LSASS process) and the SAM database. Used here in an isolated VM with Windows Defender disabled for lab purposes.
- Exfiltool — A command-line utility for packaging and preparing data for exfiltration during red team exercises. Used to bundle mock sensitive files into an archive prior to DNS tunneling.
- dnscat2 — DNS tunneling tool that encodes data within DNS query/response packets to simulate covert data exfiltration bypassing traditional firewall inspection. Client runs on target VM; server runs on attacker machine.

2.2 Lab Environment

- Attacker Machine: Kali Linux VM — IP: 192.168.1.10
- Target Machine: Windows 10 VM (lab) — IP: 192.168.1.30 (VM-02 from Lab 4)
- Network: Host-only adapter — fully isolated, no real DNS traffic sent externally
- AV Status: Windows Defender disabled within VM for lab exercise only
- Mock Data: Dummy text files created in C:\SensitiveData\ — no real data involved

3. Methodology

The lab was conducted in three sequential phases: (1) credential dumping from the Windows VM using Mimikatz, (2) packaging mock sensitive data using Exfiltool, and (3) simulating DNS tunneling exfiltration using dnscat2 within the isolated lab network.

3.1 Phase 1 — Credential Dumping (Mimikatz)

Mimikatz was executed on the Windows VM with administrator privileges. The sekurlsa::logonpasswords module was used to read credentials from LSASS memory, and



the Isadump::sam module was used to extract NTLM hashes from the SAM database. This simulates what an attacker achieves after gaining elevated access to a Windows host.

Mimikatz Modules Used: privilege::debug (enables SeDebugPrivilege)
sekurlsa::logonpasswords (dumps LSASS credentials) Isadump::sam (dumps SAM NTLM hashes)

Note: privilege::debug is required to allow Mimikatz to access LSASS memory. This requires the executing user to be a local Administrator.

3.2 Phase 2 — Data Packaging (Exfiltool)

Mock sensitive files (simulated documents named confidential_report.txt, employee_data.csv) were created in C:\SensitiveData\. Exfiltool was used to bundle these files into an archive and encode the output in preparation for DNS tunneling. All files contained dummy placeholder text — no real data was used.

Mock Data Created: C:\SensitiveData\confidential_report.txt — Contents: 'MOCK DATA - FOR LAB USE ONLY' C:\SensitiveData\employee_data.csv — Contents: 'name,email - MOCK DATA'

3.3 Phase 3 — DNS Tunneling Exfiltration (dnscat2)

dnscat2 operates by encoding data inside DNS TXT query packets and sending them to an attacker-controlled DNS server. In this lab, the dnscat2 server ran on the Kali attacker VM and the dnscat2 client on the Windows target VM. The mock data archive was transmitted through the tunnel, confirming successful covert channel establishment within the isolated lab network.

How DNS Tunneling Works (Concept): Data is split into chunks → Each chunk is Base32-encoded → Encoded chunks are sent as DNS subdomain queries (e.g., CHUNK.attacker-domain.lab) → The attacker's DNS server receives, decodes, and reassembles the data → Firewalls that allow DNS traffic pass this undetected.

The lab DNS tunnel operated entirely within the host-only network. No external DNS queries were made. The attacker's Kali VM acted as both the DNS server and the receiving endpoint.



4. Findings — Credential Dump Log

The following NTLM hashes were captured from the Windows VM SAM database and LSASS memory during the Mimikatz credential dump. All values are simulated test hashes from the isolated lab VM — no real credentials are recorded here:

Hash Type	Username	Hash Value	Source
NTLM	Administrator	aad3b435b51404eeaad3b435b51404ee:8846f7eaae8fb117ad06bdd830b7586c	SAM Database
NTLM	testuser	aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0	SAM Database
NTLM	labadmin	aad3b435b51404eeaad3b435b51404ee:e19ccf75ee54e06b06a5907af13cef42	LSASS Memory
Kerberos TGT	labadmin	[Ticket blob — 1024-byte simulated TGT captured from LSASS]	LSASS Memory

Note on Hash Values: The LM hash portion 'aad3b435b51404eeaad3b435b51404ee' is the well-known empty LM hash value, indicating LM hashing is disabled (expected on modern Windows). The NT hash values are simulated test values from the isolated lab VM only.

5. Exfiltration Summary

The DNS tunneling exfiltration was verified successfully within the isolated lab network. The table below summarises the mock exfiltration exercise:

Parameter	Details
Method	DNS Tunneling via dnscat2 (DNS TXT query encoding)
Protocol Used	DNS (UDP port 53) — commonly allowed through firewalls uninspected
Data Exfiltrated	Mock files: confidential_report.txt, employee_data.csv (dummy content only)
Archive Size	~2 KB (mock data only)
Transfer Verified	Yes — decoded file contents confirmed on attacker machine



Parameter	Details
Detection Triggered	None — no DNS inspection or DLP controls active in lab environment

6. MITRE ATT&CK Technique Log

All techniques observed during this lab are mapped to the MITRE ATT&CK Enterprise framework:

Technique	Tactic	ATT&CK ID	Description	Notes
OS Credential Dumping: LSASS Memory	Credential Access	T1003.001	Mimikatz sekurlsa reads credentials directly from LSASS process memory	NTLM hashes and Kerberos TGTs extracted from LSASS on lab VM
OS Credential Dumping: SAM	Credential Access	T1003.002	Mimikatz lsadump::sam extracts NTLM hashes from the SAM registry hive	Local account hashes for Administrator, testuser, labadmin captured
Exfiltration Over Alternative Protocol: DNS	Exfiltration	T1048.003	Data encoded and transmitted via DNS query packets to attacker-controlled resolver	Mock data tunneled via dnscat2 over UDP/53 within isolated lab
Disable or Modify Tools	Defense Evasion	T1562.001	Windows Defender AV disabled within VM to permit Mimikatz execution	AV disabled for lab purposes only; re-enabled after exercise
Data from Local System	Collection	T1005	Mock sensitive files collected from local filesystem prior to exfiltration	Dummy files in C:\SensitiveData\ packaged with Exfiltool



7. Risk Analysis

7.1 Credential Dumping Risk

- Mimikatz LSASS Dump (T1003.001) — CRITICAL. Any process with SeDebugPrivilege can read credentials from LSASS memory. On unprotected systems this requires only local admin access, allowing mass credential harvesting in seconds.
- SAM Hash Exposure (T1003.002) — HIGH. Extracted NTLM hashes can be used directly in pass-the-hash attacks (T1550.002) or cracked offline using tools such as Hashcat — no plaintext password needed for lateral movement.
- Kerberos Ticket Theft — CRITICAL. Stolen TGTs (pass-the-ticket) allow impersonation of legitimate users across an Active Directory domain without triggering password-based authentication alerts.

7.2 Exfiltration Risk

- DNS Tunneling (T1048.003) — HIGH. DNS is almost universally permitted through enterprise firewalls. Without DNS inspection or monitoring, covert data exfiltration over DNS is effectively silent and can persist for extended periods.
- No DLP Triggered — The absence of Data Loss Prevention (DLP) controls in the lab environment meant the exfiltration was completed with zero alerts, reflecting a common real-world gap.

8. Recommendations

8.1 Prevent Credential Dumping

- Enable Windows Defender Credential Guard — virtualises LSASS using Hyper-V to prevent direct memory reading by tools like Mimikatz.
- Enable Protected Users Security Group — restricts use of NTLM authentication for sensitive accounts, preventing pass-the-hash.
- Deploy an EDR solution (e.g., Microsoft Defender for Endpoint) to detect and block Mimikatz execution patterns, LSASS access, and SeDebugPrivilege abuse.
- Restrict local administrator rights — implement Privileged Access Workstations (PAWs) and LAPS to limit the blast radius of a compromised endpoint.

8.2 Prevent & Detect DNS Exfiltration

- Deploy a DNS Security solution (e.g., Cisco Umbrella, Palo Alto DNS Security) to inspect DNS traffic for anomalous query patterns — unusually long subdomains and high-frequency TXT queries are strong DNS tunneling indicators.



- Implement Data Loss Prevention (DLP) controls on endpoints and network egress points to detect and block bulk file staging and exfiltration attempts.
- Restrict outbound DNS to a single authorised internal resolver — block direct DNS to external resolvers from endpoints.
- Monitor DNS logs via SIEM for entropy analysis: DNS tunneling queries have abnormally high entropy in subdomain strings compared to legitimate traffic.

9. Conclusion

This lab demonstrated two critical post-exploitation capabilities: credential harvesting via Mimikatz and covert data exfiltration via DNS tunneling. Both techniques are widely used by advanced threat actors and nation-state groups and represent the final stages of an attack lifecycle before the defender detects the breach.

The exercises reinforced that post-exploitation is where the most significant damage occurs — stolen credentials enable domain-wide compromise, while undetected exfiltration channels allow sensitive data to leave the organisation silently. Defence must focus on both prevention (Credential Guard, DLP) and detection (EDR, DNS monitoring, SIEM).

Key Takeaway: Credentials are the keys to the kingdom. Once harvested, NTLM hashes require no cracking to enable lateral movement and domain compromise. Combined with a covert DNS exfiltration channel, an attacker can achieve full data theft with zero traditional security alerts.

10. Learning Outcomes

- Understood how Mimikatz reads credentials from LSASS memory and the SAM database on a Windows system.
- Learned the difference between NTLM hash extraction (SAM/LSASS) and Kerberos ticket theft, and their respective attack use-cases.
- Understood DNS tunneling as a covert exfiltration technique that bypasses conventional firewall inspection.
- Mapped all techniques to the MITRE ATT&CK framework (T1003.001, T1003.002, T1048.003, T1562.001, T1005).
- Formulated targeted defensive recommendations for credential protection and DNS-based exfiltration detection.